Chapter 3 / Capítulo 3

Self-assessment / Autoevaluación

Source / Fuente: CISA Official Review Manual, ISACA. Material proporcionado por el usuario. Traducción no oficial. Se incluyen las explicaciones completas de A, B, C y D. Los guiones son explicaciones propias para responder oralmente, no citas del manual.

Question 1 / Pregunta 1

English: To assist in testing an essential banking system being acquired, an enterprise has provided the vendor with sensitive data from its existing production system. An information systems (IS) auditor's PRIMARY concern is that the data should be:

A. sanitized.

B. complete.

C. representative.

D. current.

Español: Para ayudar a probar un sistema bancario esencial que se está adquiriendo, una empresa ha proporcionado al proveedor datos sensibles de su sistema de producción actual. La preocupación PRINCIPAL de un auditor de sistemas de información (SI) es que los datos estén:

A. Sanitizados (sin información sensible identificable).

B. Completos.

C. Sean representativos.

D. Actualizados.

Correct answer / Respuesta correcta: A

Explanation of every option / Justificación de cada alternativa

A. Correct / Correcta

English: Test data should be sanitized to prevent sensitive data from leaking to unauthorized persons.

Español: Los datos de prueba deben sanitizarse para evitar que la información sensible se filtre a personas no autorizadas.

B. Incorrect / Incorrecta

English: Although it is important that the data set be complete, the primary concern is that test data should be sanitized to prevent sensitive data from leaking to unauthorized persons.

Español: Aunque es importante que el conjunto de datos esté completo, la preocupación principal es sanitizar los datos de prueba para evitar filtraciones de información sensible.

C. Incorrect / Incorrecta

English: Although it is important to encompass a representation of the transactional data, the primary concern is that test data should be sanitized to prevent sensitive data from leaking to unauthorized persons.

Español: Aunque es importante incluir una representación de los datos de las transacciones, la preocupación principal es sanitizar los datos de prueba para evitar filtraciones de información sensible.

D. Incorrect / Incorrecta

English: Although it is important that the data set represent current data being processed, the primary concern is that test data should be sanitized to prevent sensitive data from leaking to unauthorized persons.

Español: Aunque es importante que el conjunto de datos represente la información que se procesa actualmente, la preocupación principal es sanitizar los datos de prueba para evitar filtraciones de información sensible.

Suggested speaking script / Guion sugerido

English: I would choose A because the vendor needs test data without access to sensitive customer information. Sanitizing the data reduces the risk of exposing that information.

Español: Elegiría la A porque el proveedor necesita datos para probar el sistema sin acceder a información sensible de los clientes. Sanitizar los datos reduce el riesgo de exponer esa información.

Question 2 / Pregunta 2

English: Which of the following is the PRIMARY purpose for conducting parallel testing?

A. To determine whether the system is cost-effective
B. To enable comprehensive unit and system testing
C. To highlight errors in the program interfaces with files
D. To ensure that the new system meets user requirements

Español: ¿Cuál es el propósito PRINCIPAL de realizar pruebas en paralelo?

A. Determinar si el sistema es rentable.
B. Permitir pruebas exhaustivas de unidad y de sistema.
C. Detectar errores en las interfaces de los programas con los archivos.
D. Garantizar que el nuevo sistema cumpla los requisitos de los usuarios.

Correct answer / Respuesta correcta: D

Explanation of every option / Justificación de cada alternativa

A. Incorrect / Incorrecta

English: Parallel testing may show that the old system is more cost-effective than the new system, but this is not the primary reason.

Español: Las pruebas en paralelo pueden mostrar que el sistema anterior es más rentable que el nuevo, pero ese no es su propósito principal.

B. Incorrect / Incorrecta

English: Unit and system testing are completed before parallel testing.

Español: Las pruebas de unidad y de sistema se completan antes de las pruebas en paralelo.

C. Incorrect / Incorrecta

English: Program interfaces with files are tested for errors during system testing.

Español: Los errores en las interfaces de los programas con los archivos se comprueban durante las pruebas de sistema.

D. Correct / Correcta

English: The purpose of parallel testing is to ensure that the implementation of a new system will meet user requirements.

Español: El propósito de las pruebas en paralelo es garantizar que la implementación de un nuevo sistema cumpla los requisitos de los usuarios.

Suggested speaking script / Guion sugerido

English: I would choose D because parallel testing lets us compare the old and new systems using the same inputs. This helps confirm that the new system produces the expected results and meets user requirements.

Español: Elegiría la D porque las pruebas en paralelo permiten comparar el sistema anterior y el nuevo con los mismos datos de entrada. Así se comprueba que el nuevo sistema produzca los resultados esperados y cumpla los requisitos de los usuarios.

Question 3 / Pregunta 3

English: When conducting a review of business process reengineering (BPR), an IS auditor finds that an important preventive control has been removed. In this case, the IS auditor should:

A. inform management of the finding and determine whether management is willing to accept the potential material risk of not having that preventive control.

B. determine if a detective control has replaced the preventive control during the process, and, if it has not, report the removal of the preventive control.

C. recommend that this and all control procedures that existed before the process was reengineered be included in the new process.

D. develop a continuous audit approach to monitor the effects of the removal of the preventive control.

Español: Al revisar la reingeniería de procesos de negocio (BPR), un auditor de SI descubre que se ha eliminado un control preventivo importante. En este caso, el auditor debería:

A. Informar a la dirección sobre el hallazgo y determinar si está dispuesta a aceptar el riesgo potencial significativo de no contar con ese control preventivo.

B. Determinar si un control detectivo ha reemplazado al preventivo durante el proceso y, si no es así, informar de la eliminación del control preventivo.

C. Recomendar que este y todos los controles que existían antes de la reingeniería se incluyan en el nuevo proceso.

D. Desarrollar un enfoque de auditoría continua para supervisar los efectos de la eliminación del control preventivo.

Correct answer / Respuesta correcta: A

Explanation of every option / Justificación de cada alternativa

A. Correct / Correcta

English: Management should be informed immediately to determine whether they are willing to accept the potential material risk of not having that preventive control in place.

Español: Debe informarse inmediatamente a la dirección para determinar si está dispuesta a aceptar el riesgo potencial significativo de no contar con ese control preventivo.

B. Incorrect / Incorrecta

English: The existence of a detective control instead of a preventive control usually increases the risk that a material problem may occur.

Español: La existencia de un control detectivo en lugar de uno preventivo suele aumentar el riesgo de que ocurra un problema significativo.

C. Incorrect / Incorrecta

English: Often, during business process reengineering (BPR), many nonvalue-added controls are eliminated. This is good, unless the controls increase the business and financial risk.

Español: A menudo, durante la reingeniería de procesos de negocio (BPR), se eliminan muchos controles que no aportan valor. Esto es positivo, salvo que los controles aumenten el riesgo empresarial y financiero.

D. Incorrect / Incorrecta

English: An IS auditor may want to monitor, or recommend that management monitor, the new process, but this should be done only after management has been informed and accepts the risk of not having the preventive control in place.

Español: El auditor de SI puede supervisar el nuevo proceso o recomendar que la dirección lo haga, pero únicamente después de que esta haya sido informada y haya aceptado el riesgo de no contar con el control preventivo.

Suggested speaking script / Guion sugerido

English: I would choose A because removing an important preventive control can expose the business to significant risk. The auditor should report it, and management must decide whether to accept that risk.

Español: Elegiría la A porque eliminar un control preventivo importante puede exponer al negocio a un riesgo significativo. El auditor debe comunicarlo y la dirección debe decidir si acepta ese riesgo.

Question 4 / Pregunta 4

English: Which of the following data validation edits is effective in detecting transposition and transcription errors?

A. Range check
B. Check digit
C. Validity check
D. Duplicate check

Español: ¿Cuál de los siguientes controles de validación de datos es eficaz para detectar errores de transposición y de transcripción?

A. Verificación de rango.
B. Dígito de control.
C. Verificación de validez.
D. Verificación de duplicados.

Correct answer / Respuesta correcta: B

Explanation of every option / Justificación de cada alternativa

A. Incorrect / Incorrecta

English: A range check is checking data that match a predetermined range of values.

Español: La verificación de rango comprueba que los datos se encuentren dentro de un intervalo de valores predeterminado.

B. Correct / Correcta

English: A check digit is a numeric value that is calculated mathematically and appended to data to ensure that the original data have not been altered (e.g., an incorrect, but valid, value substituted for the original). This control is effective in detecting transposition and transcription errors.

Español: Un dígito de control es un valor numérico calculado matemáticamente que se añade a los datos para comprobar que los datos originales no hayan sido alterados; por ejemplo, que un valor incorrecto, aunque válido, no haya sustituido al original. Este control detecta eficazmente errores de transposición y de transcripción.

C. Incorrect / Incorrecta

English: An availability check is programmed checking of the data validity in accordance with predetermined criteria.

Español: Una verificación de disponibilidad es una comprobación programada de la validez de los datos de acuerdo con criterios predeterminados.

D. Incorrect / Incorrecta

English: In a duplicate check, new or fresh transactions are matched to those previously entered to ensure that they are not already in the system.

Español: La verificación de duplicados compara las nuevas transacciones con las ingresadas anteriormente para asegurarse de que no estén ya en el sistema.

Nota del original: La opción C dice “Validity check”, pero su explicación usa “availability check”. Se conserva y traduce la terminología de ambos textos.

Suggested speaking script / Guion sugerido

English: I would choose B because a check digit is calculated from the original data. If a digit is mistyped or digits are swapped, the check can detect the error.

Español: Elegiría la B porque el dígito de control se calcula a partir de los datos originales. Si se escribe mal un número o se cambia el orden de los dígitos, la verificación puede detectar el error.

Question 5 / Pregunta 5

English: Which of the following weaknesses would be considered the MOST significant in enterprise resource planning (ERP) software used by a financial enterprise?

A. Access controls have not been reviewed.

B. Limited documentation is available.

C. Two-year-old backup media have not been replaced.

D. Database backups are performed once a day.

Español: ¿Cuál de las siguientes debilidades se consideraría la MÁS significativa en un software de planificación de recursos empresariales (ERP) utilizado por una empresa financiera?

A. Los controles de acceso no se han revisado.

B. La documentación disponible es limitada.

C. Los medios de respaldo de dos años de antigüedad no se han reemplazado.

D. Las copias de seguridad de la base de datos se realizan una vez al día.

Correct answer / Respuesta correcta: A

Explanation of every option / Justificación de cada alternativa

A. Correct / Correcta

English: A lack of review of access controls in a financial enterprise can have serious consequences given the types of data and assets that can be accessed.

Español: La falta de revisión de los controles de acceso en una empresa financiera puede tener consecuencias graves por los tipos de datos y activos a los que se puede acceder.

B. Incorrect / Incorrecta

English: A lack of documentation may not be as serious as not having properly reviewed access controls.

Español: La falta de documentación puede ser menos grave que no haber revisado adecuadamente los controles de acceso.

C. Incorrect / Incorrecta

English: It may not be possible to retrieve data from two-year-old backup media.

Español: Puede que no sea posible recuperar los datos de medios de respaldo de dos años de antigüedad.

D. Incorrect / Incorrecta

English: It may be acceptable to the business to perform database backups once a day, depending on the volume of transactions.

Español: Realizar copias de seguridad de la base de datos una vez al día puede ser aceptable para el negocio, dependiendo del volumen de transacciones.

Suggested speaking script / Guion sugerido

English: I would choose A because access controls determine who can view or change financial information. Without reviewing them, inappropriate permissions could remain active.

Español: Elegiría la A porque los controles de acceso determinan quién puede ver o modificar información financiera. Si no se revisan, podrían mantenerse permisos inadecuados.

Question 6 / Pregunta 6

English: When auditing the requirements phase of a software acquisition, an IS auditor should:

A. assess the reasonability of the project timetable.
B. assess the vendor's proposed quality processes.
C. ensure that the best software package is acquired.
D. review the completeness of the specifications.

Español: Al auditar la fase de requisitos de una adquisición de software, un auditor de SI debería:

A. Evaluar si el cronograma del proyecto es razonable.
B. Evaluar los procesos de calidad propuestos por el proveedor.
C. Garantizar que se adquiera el mejor paquete de software.
D. Revisar que las especificaciones estén completas.

Correct answer / Respuesta correcta: D

Explanation of every option / Justificación de cada alternativa

A. Incorrect / Incorrecta

English: A project timetable normally is not found in a requirements document.

Español: El cronograma de un proyecto normalmente no forma parte del documento de requisitos.

B. Incorrect / Incorrecta

English: Assessing the vendor quality processes comes after the requirements have been completed.

Español: La evaluación de los procesos de calidad del proveedor se realiza después de completar los requisitos.

C. Incorrect / Incorrecta

English: The decision to purchase a package from a vendor comes after the requirements have been completed.

Español: La decisión de comprar un paquete a un proveedor se toma después de completar los requisitos.

D. Correct / Correcta

English: The purpose of the requirements phase is to specify the functionality of the proposed system; therefore, an information systems (IS) auditor would concentrate on the completeness of the specifications.

Español: La finalidad de la fase de requisitos es especificar la funcionalidad del sistema propuesto; por ello, el auditor de SI se concentra en que las especificaciones estén completas.

Suggested speaking script / Guion sugerido

English: I would choose D because the requirements phase defines what the system must do. Incomplete specifications can lead to acquiring software that does not meet the business needs.

Español: Elegiría la D porque en la fase de requisitos se define qué debe hacer el sistema. Si las especificaciones están incompletas, se puede adquirir un software que no responda a las necesidades del negocio.

Question 7 / Pregunta 7

English: An enterprise decides to purchase a software package instead of developing it. In such a case, the design and development phases of a traditional system development life cycle (SDLC) are replaced with:

A. selection and configuration phases.

B. feasibility and requirements phases.

C. implementation and testing phases.

D. nothing, because replacement is not required.

Español: Una empresa decide comprar un paquete de software en lugar de desarrollarlo. En ese caso, las fases de diseño y desarrollo del ciclo de vida tradicional de desarrollo de sistemas (SDLC) se sustituyen por:

A. Las fases de selección y configuración.

B. Las fases de viabilidad y requisitos.

C. Las fases de implementación y pruebas.

D. Ninguna fase, porque no es necesario sustituirlas.

Correct answer / Respuesta correcta: A

Explanation of every option / Justificación de cada alternativa

A. Correct / Correcta

English: With a purchased package, the design and development phases of the traditional life cycle are replaced with selection and configuration phases. A proposal from the supplier of packaged systems is requested and evaluated against predefined criteria for selection, before a decision is made to purchase the software. After the software is purchased, it is configured to meet the enterprise's requirements.

Español: Cuando se compra un paquete, las fases de diseño y desarrollo del ciclo de vida tradicional se sustituyen por las fases de selección y configuración. Se solicita una propuesta al proveedor y se evalúa con criterios de selección predefinidos antes de decidir la compra. Después de adquirir el software, se configura para satisfacer los requisitos de la empresa.

B. Incorrect / Incorrecta

English: The other phases of the system development life cycle (SDLC), such as feasibility study, requirements definition, implementation and postimplementation, remain unaltered.

Español: Las otras fases del SDLC, como el estudio de viabilidad, la definición de requisitos, la implementación y la posimplementación, se mantienen sin cambios.

C. Incorrect / Incorrecta

English: The other phases of the SDLC, such as feasibility study, requirements definition, implementation and postimplementation, remain unaltered.

Español: Las otras fases del SDLC, como el estudio de viabilidad, la definición de requisitos, la implementación y la posimplementación, se mantienen sin cambios.

D. Incorrect / Incorrecta

English: In this scenario, the design and development phases of the traditional life cycle are replaceable with selection and configuration phases.

Español: En este escenario, las fases de diseño y desarrollo del ciclo de vida tradicional pueden sustituirse por las fases de selección y configuración.

Suggested speaking script / Guion sugerido

English: I would choose A because the company is buying software that already exists. It must select the most suitable package and configure it to meet its requirements.

Español: Elegiría la A porque la empresa compra un software que ya existe. Debe seleccionar el paquete más adecuado y configurarlo para cumplir sus requisitos.

Question 8 / Pregunta 8

English: User specifications for a software development project using the traditional (waterfall) system development life cycle methodology have not been met. Which of the following areas is the MOST likely source of the cause of this issue?

A. Quality assurance (QA)

B. Requirements

C. Development

D. User training

Español: No se han cumplido las especificaciones de los usuarios en un proyecto de desarrollo de software que utiliza la metodología tradicional del ciclo de vida de desarrollo de sistemas en cascada. ¿En cuál de las siguientes áreas se encuentra la causa MÁS probable del problema?

A. Aseguramiento de la calidad (QA).

B. Requisitos.

C. Desarrollo.

D. Capacitación de los usuarios.

Correct answer / Respuesta correcta: C

Explanation of every option / Justificación de cada alternativa

A. Incorrect / Incorrecta

English: Quality assurance (QA) has its focus on formal aspects of software development, such as adhering to coding standards or a specific development methodology.

Español: El aseguramiento de la calidad se centra en aspectos formales del desarrollo de software, como el cumplimiento de estándares de programación o de una metodología de desarrollo específica.

B. Incorrect / Incorrecta

English: To fail at user specifications implies that requirements engineering has been done to describe the users' demands. Otherwise, there would not be a baseline of specifications against which to check.

Español: El incumplimiento de las especificaciones de los usuarios implica que la ingeniería de requisitos ya se realizó para describir sus demandas. De lo contrario, no existiría una base de especificaciones contra la cual comprobar el cumplimiento.

C. Correct / Correcta

English: Project management failed to either set up or verify controls that provide for software or software modules under development that adhere to those user specifications.

Español: La gestión del proyecto no estableció o no verificó controles que garantizaran que el software o los módulos en desarrollo se ajustaran a las especificaciones de los usuarios.

D. Incorrect / Incorrecta

English: A failure to meet user specifications might show up during user training or acceptance testing but is not the cause.

Español: El incumplimiento de las especificaciones puede detectarse durante la capacitación de los usuarios o las pruebas de aceptación, pero estas no son su causa.

Suggested speaking script / Guion sugerido

English: I would choose C because the specifications already exist, but the software does not meet them. The likely problem is that development controls did not ensure that the implementation followed those specifications.

Español: Elegiría la C porque las especificaciones ya existen, pero el software no las cumple. Lo más probable es que los controles del desarrollo no hayan asegurado que la implementación siguiera esas especificaciones.

Question 9 / Pregunta 9

English: When introducing thin client architecture, which of the following types of risk regarding servers is significantly increased?

A. Integrity
B. Concurrency
C. Confidentiality
D. Availability

Español: Al introducir una arquitectura de clientes ligeros, ¿cuál de los siguientes tipos de riesgo relacionado con los servidores aumenta significativamente?

A. Integridad.
B. Concurrencia.
C. Confidencialidad.
D. Disponibilidad.

Correct answer / Respuesta correcta: D

Explanation of every option / Justificación de cada alternativa

A. Incorrect / Incorrecta

English: Because the other elements do not need to change, the integrity risk is not increased.

Español: Como los demás elementos no necesitan cambiar, el riesgo de integridad no aumenta.

B. Incorrect / Incorrecta

English: Because the other elements do not need to change, the concurrency risk is not increased.

Español: Como los demás elementos no necesitan cambiar, el riesgo de concurrencia no aumenta.

C. Incorrect / Incorrecta

English: Because the other elements do not need to change, the confidentiality risk is not increased.

Español: Como los demás elementos no necesitan cambiar, el riesgo de confidencialidad no aumenta.

D. Correct / Correcta

English: The main change when using thin client architecture is making the servers critical to the operation. Therefore, the probability that one of them fails is increased and, as a result, the availability risk is increased.

Español: El principal cambio al utilizar una arquitectura de clientes ligeros es que los servidores se vuelven críticos para la operación. Por lo tanto, aumenta la probabilidad de que uno de ellos falle y, como resultado, aumenta el riesgo de disponibilidad.

Suggested speaking script / Guion sugerido

English: I would choose D because thin clients depend heavily on servers. If a critical server becomes unavailable, users may be unable to work.

Español: Elegiría la D porque los clientes ligeros dependen mucho de los servidores. Si un servidor crítico deja de estar disponible, los usuarios pueden quedarse sin poder trabajar.

Question 10 / Pregunta 10

English: Which of the following is MOST commonly associated with an agile development methodology?

A. Reliance on detailed documentation

B. Reliance on strict standard operating procedures

C. Lack of user requirements

D. Heavy reliance on tacit knowledge

Español: ¿Cuál de las siguientes características se asocia MÁS comúnmente con una metodología de desarrollo ágil?

A. Dependencia de documentación detallada.

B. Dependencia de procedimientos operativos estándar estrictos.

C. Ausencia de requisitos de los usuarios.

D. Gran dependencia del conocimiento tácito.

Correct answer / Respuesta correcta: D

Explanation of every option / Justificación de cada alternativa

A. Incorrect / Incorrecta

English: Project documentation is generally second to actual functionality for agile development methodology.

Español: En el desarrollo ágil, la documentación del proyecto generalmente ocupa un lugar secundario frente a la funcionalidad real.

B. Incorrect / Incorrecta

English: Strict standard operating procedures would be detrimental to a developer's ability to think creatively and collaboratively.

Español: Los procedimientos operativos estándar estrictos perjudicarían la capacidad del desarrollador para pensar de forma creativa y colaborativa.

C. Incorrect / Incorrecta

English: All development methodologies require some form of requirements definition. Agile relies on clear requirements being defined up front.

Español: Todas las metodologías de desarrollo requieren alguna forma de definición de requisitos. Según la clave, el enfoque ágil se apoya en requisitos claros definidos desde el inicio.

D. Correct / Correcta

English: Tacit knowledge (i.e., implicit knowledge gained from experience and difficult to document) is leveraged greatly by agile methods to increase collaboration and creativity of development teams.

Español: Los métodos ágiles aprovechan en gran medida el conocimiento tácito, es decir, el conocimiento implícito adquirido mediante la experiencia y difícil de documentar, para aumentar la colaboración y la creatividad de los equipos de desarrollo.

Suggested speaking script / Guion sugerido

English: I would choose D because agile teams rely heavily on collaboration and experience. Much of that practical knowledge is shared through communication and is difficult to fully document.

Español: Elegiría la D porque los equipos ágiles se apoyan mucho en la colaboración y la experiencia. Gran parte de ese conocimiento práctico se comparte mediante la comunicación y es difícil de documentar por completo.